



АКАДЕМИЯ
КОДЕБАЙ

ПРОФЕССИЯ ПЕНТЕСТЕР

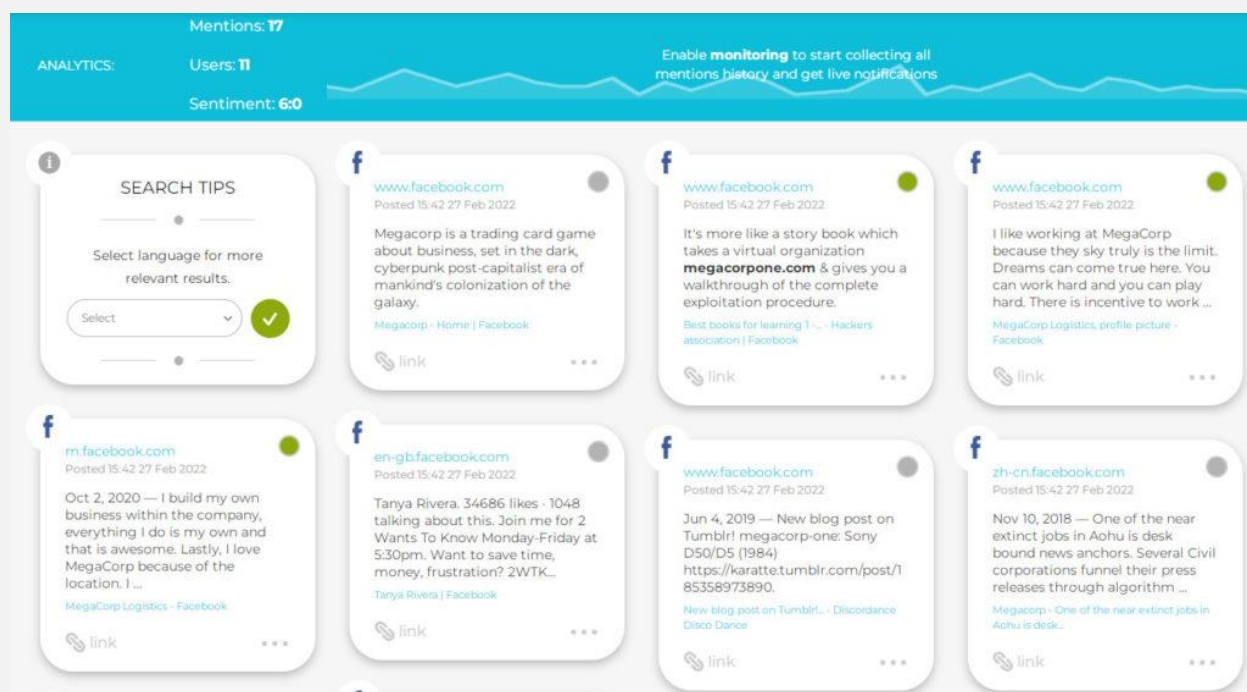
Друзья, всех приветствую!

Практически все организации в настоящее время в той или иной степени представлены в социальных сетях. Информация, которую размещает компания, может быть очень полезной для нас. Например, мы можем использовать эту информацию для выявления потенциальных сотрудников и получения дополнительной информации о компании и ее деятельности.

Существуют различные способы сбора этой публичной информации с помощью нескольких инструментов, которые мы уже обсуждали, например, Recon-ng и theHarvester. Давайте рассмотрим несколько дополнительных инструментов.

Social-Searcher

[Social-Searcher](#) — это поисковая система по сайтам социальных сетей, она помогает находить и отслеживать упоминания о людях, брендах или любых ключевых словах в социальных сетях и на других платформах. Его можно использовать как для маркетингового анализа, так и для задач информационной безопасности и пентестинга. Бесплатная учетная запись позволяет ограниченное количество поисковых запросов в день:



Результаты поиска будут включать информацию, размещенную целевой организацией, и то, что люди говорят о ней. Помимо прочего, Social-Searcher

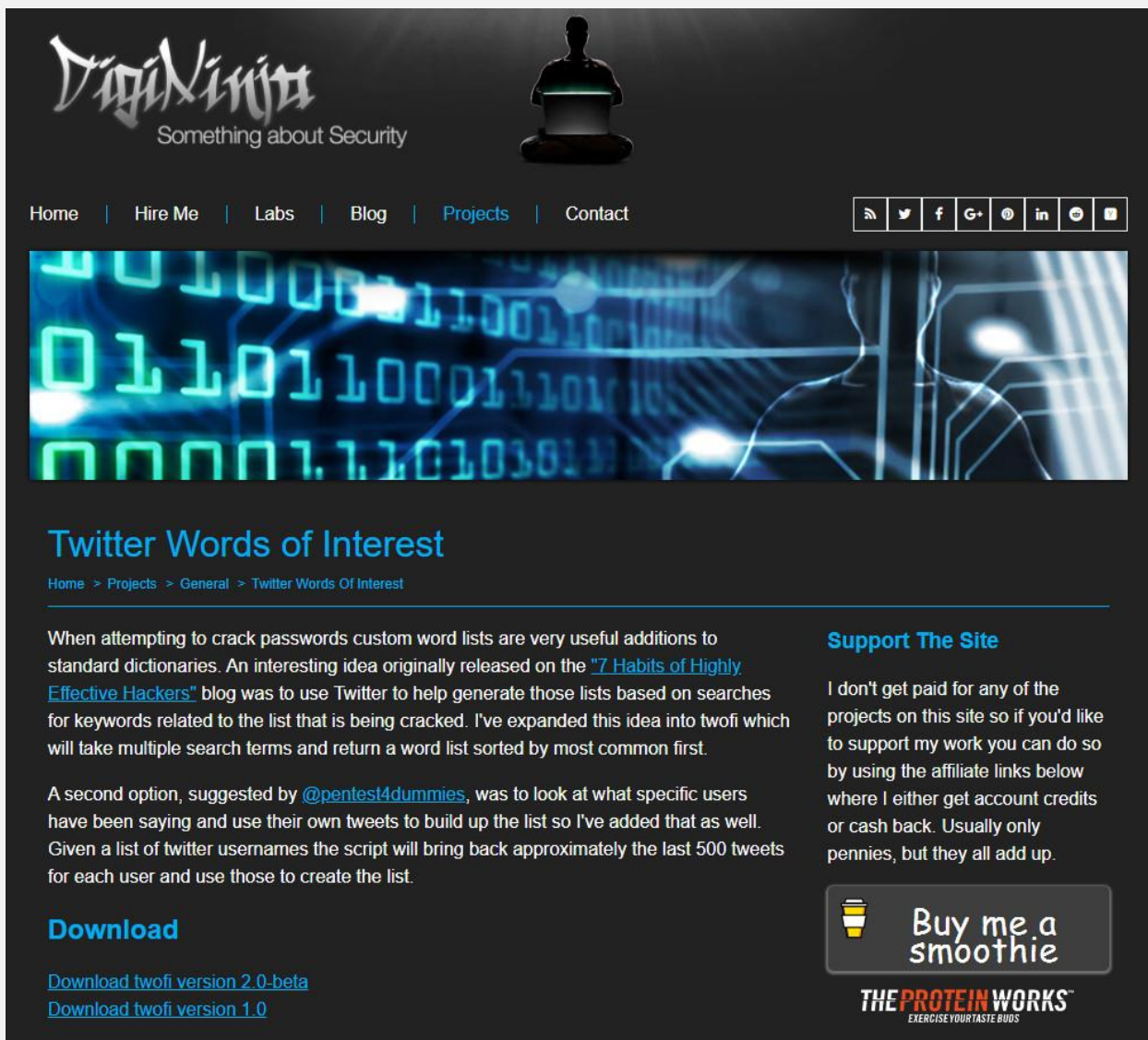
может помочь нам определить, какой "след" и охват организации существует в социальных сетях. Среди возможностей этого сервиса:

- Мониторинг упоминаний в реальном времени. Позволяет отслеживать публикации на таких платформах, как Twitter, Facebook, Instagram, Reddit и других.
- Поиск по ключевым словам. Удобно для поиска специфических запросов, связанных с целями аудита или атаки.
- Фильтрация результатов. Можно фильтровать информацию по типу контента (текст, изображение, видео), что ускоряет анализ.
- Аналитика настроений. Social-Searcher анализирует эмоциональную окраску контента, что полезно для оценки общественной реакции или настроений вокруг определенной темы.
- Проверка личных данных. Social-Searcher помогает искать утечки данных о пользователях, в том числе пароли или другие личные сведения, которые могли оказаться в открытом доступе.
- Проверка сотрудников на утечку информации. Возможно выявить, если сотрудники компании несанкционированно делятся важной информацией через социальные сети.
- Поиск по киберугрозам. Можно использовать для отслеживания упоминаний о компании или системе в контексте хакерских атак или угроз.
- OSINT-процессы. В рамках пентестинга, когда необходимо собрать информацию о цели, этот инструмент может предоставить полезные данные о людях, их привычках и поведении в сети.
- Социальная инженерия. Полученные данные можно использовать для разработки сценариев социальной инженерии, нацеленной на сотрудников компании.

Social-Searcher предоставляет данные из открытых источников, и для его использования не нужно создавать аккаунты или авторизоваться, что делает его инструментом для быстрой и ненавязчивой разведки. Однако поиск не охватывает закрытые профили и приватные данные, поэтому его возможности ограничены только публичной информацией.

Social-Searcher – мощный инструмент для сбора данных, который может использоваться как для легитимного мониторинга, так и для более специфичных задач в контексте пентестинга.

Twofi



The screenshot shows the Twofi website interface. At the top, there's a header with the 'Dag Ninja' logo and the tagline 'Something about Security'. A navigation menu includes links for Home, Hire Me, Labs, Blog, Projects, and Contact. Social media icons for RSS, Twitter, Facebook, Google+, LinkedIn, and YouTube are also present. Below the header is a large banner image featuring binary code and circuitry. The main content area is titled 'Twitter Words of Interest' and includes a breadcrumb trail: Home > Projects > General > Twitter Words Of Interest. The text explains the tool's purpose: to generate word lists for password cracking by analyzing Twitter data. It mentions two methods: one based on keyword searches and another based on specific user tweets. A 'Download' section provides links for 'twofi version 2.0-beta' and 'twofi version 1.0'. On the right side, there's a 'Support The Site' section with a text-based appeal and a 'Buy me a smoothie' button with a coffee icon. At the bottom right, there's an advertisement for 'THE PROTEIN WORKS' with the tagline 'EXERCISE YOUR TASTE BUDS'.

Есть еще один инструмент, с которым мы возможно захотим ознакомиться. [Twofi](#) сканирует Twitter (X) пользователя и генерирует персонализированный список слов, используемый для парольных атак на этого пользователя. Хотя мы не будем проводить никаких атак во время пассивного сбора информации, но мы можем запустить этот инструмент направив его на любые аккаунты в Twitter (X), которые мы идентифицировали, чтобы иметь готовый список слов, на случай, когда это будет необходимо. Для работы Twofi требуется действующий API-ключ Twitter (X).

Как работает Twofi?

1. Сбор информации с Twitter: Twofi извлекает данные с аккаунтов Twitter на основе определенных ключевых слов, связанных с пользователем или организацией, чьим Wi-Fi вы хотите получить доступ. Это могут быть твиты, биографии, хэштеги и другая информация, которую пользователь публикует в открытом доступе.
2. Анализ и генерация паролей: На основе собранной информации Twofi использует специальные шаблоны для создания возможных комбинаций паролей. К примеру, он может брать любимые фразы или числа, которые часто упоминает пользователь, и строить из них предположения.
3. Попытка использования пароля: Сгенерированные комбинации паролей могут быть использованы для дальнейшего тестирования в попытке получить доступ к Wi-Fi сети.

Пример сценария атаки с использованием Twofi:

Допустим, мы собираем информацию о конкретном сотруднике компании через его открытый Twitter-профиль. Человек может публиковать твиты о своих любимых фильмах, датах рождения членов семьи, названиях домашних животных и других личных вещах. Twofi обрабатывает эту информацию и генерирует список возможных паролей для использования в атаках.

Применение в пентестинге:

В рамках этического хакинга и пентестинга Twofi может быть полезен для демонстрации угроз, связанных с человеческим фактором. Особенно это важно в контексте создания политик информационной безопасности, касающихся управления паролями.

- OSINT: Twofi показывает важность понимания того, какую информацию пользователи оставляют в открытом доступе. Разведка на основе открытых источников данных может позволить злоумышленникам

получить доступ к конфиденциальным данным через слабые пароли, основанные на личной информации.

- Социальная инженерия: Поскольку TwoFi базируется на данных из социальных сетей, он подчеркивает важность обучения сотрудников безопасному поведению в сети, включая советы по минимизации публикации личной информации.